FOR FREELANCERS · CONSULTANTS · SOLO AGENCIES

THE FREELANCER'S

DATA *Protection Guide*

CONTRACTS & FILES

How to Protect Client Information, Contracts and Digital Work



CLIENT DATA · **SECURE** FILE SHARING · **CONFIDENTIALITY** & GDPR

DPA CLAUSES · CHECKLISTS · 30-DAY PLAN

ZIRLANDIA MILKOVIC



THE FREELANCER'S

DATA Protection Guide

CONTRACTS & FILES

How to Protect Client Information, Contracts and Digital Work: working with client data, secure file sharing, confidentiality and your GDPR responsibilities

ZIRLANDIA MILKOVIC

FOR FREELANCERS · CONSULTANTS · SOLO AGENCIES

The Freelancer's Data Protection Guide

How to Protect Client Information, Contracts and Digital Work: working with client data, secure file sharing, confidentiality and your GDPR responsibilities

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced, stored or transmitted in any form without written permission, except for brief quotations in reviews and for printing the worksheets, checklists and the notice templates for your own business use.

NOT LEGAL ADVICE. This book is an educational guide to the EU General Data Protection Regulation (Regulation (EU) 2016/679). It is not legal advice, does not create a lawyer-client or consultant-client relationship, and does not take your individual circumstances into account. Reading it, following it or using its templates does not make a business GDPR compliant and is not a certification or a guarantee of compliance.

LAWS CHANGE. Data protection law, regulatory guidance, court decisions and national rules develop continuously. The book reflects the author's understanding as of its publication date (2026) and refers to official sources so that you can check what applies now. National laws, supervisory-authority guidance and sector rules differ between countries. Before you rely on anything here for a decision with real consequences, take advice from a qualified lawyer or data protection professional in the relevant country.

Product and company names (for example email, analytics, advertising and AI platforms) are the property of their respective owners and are used only as examples for identification and education. This independent book is not affiliated with, sponsored by or endorsed by any of them, and no product is recommended or certified as compliant.

Every person, business and incident described in the case studies and scenarios is fictional and was created to illustrate ideas. Any resemblance to real people or companies is coincidental.

Premium Edition 2026 · PDF with clickable contents, bookmarks and fillable worksheets

Contents

Note	A Note from the Author	5
01	You Are Already Handling Other People's Data	6
02	Mapping the Client Data You Hold	10
03	Your Role Under the GDPR	14
04	Contracts, NDAs and Data Processing Agreements	18
05	Confidentiality in Everyday Freelance Life	22
06	Secure File Sharing	26
07	Locking Down Your Devices and Accounts	30
08	Tools, Sub-Processors, AI and International Transfers	34
09	Retention, Deletion and Closing a Project	38
10	When Something Goes Wrong	42
11	Your 30-Day Freelancer Protection Plan	46
Bonus	Freelancer Data Protection Toolkit	50
A–Z	Plain-English Glossary	56
Ref	Official Sources & Further Reading	58
Bio	About the Author	59

A Note from the Author

Why a freelancer needs a data protection habit, and how to use this book in an afternoon.

You probably did not become a freelancer to think about data protection. You became one to design, write, code, consult, translate, coach or manage, and to do it on your own terms. Yet every project quietly puts other people's information in your hands: a client's customer list, a contract with salary figures, a shared drive full of invoices, a login to a website that holds thousands of accounts.

That information is not yours. It belongs to your client, and in most cases to the people behind the names in the spreadsheet. You are trusted with it, usually without anyone saying so out loud. And because you work alone, there is no IT department, no legal team and no compliance officer between a small mistake and a real problem. There is just you, your laptop and a deadline.

The good news is that protecting client data does not take a big budget or a legal degree. It takes a handful of habits, a few well-chosen clauses in your contracts and a clear idea of what the GDPR actually asks of you. That is what this book gives you, in plain English, with the checklists and templates to put it into practice.

The book follows the life of a typical project. First you will learn what data you really handle and what role the law gives you. Then you will see how to write that into your contracts and keep client confidences. After that comes the practical part: sharing files securely, locking down your devices, choosing tools and using AI assistants without leaking anything. Finally you will learn what to do when something goes wrong and how to close a project cleanly.

> GOOD TO KNOW **How to use this book**
>
> **If you have one afternoon**, read Chapters 1, 3 and 6, fill in the data map and the client data sheet in the Bonus toolkit, and switch on multi-factor authentication everywhere. **If you have a week**, read the whole book and work through the 30-day plan in Chapter 11. Examples are fictional. Throughout, "GDPR" means the EU General Data Protection Regulation, and the book is written for freelancers working with clients in Europe, wherever you are based.

PART I · KNOW WHAT YOU HOLD

CHAPTER

01

You Are Already Handling Other People's Data

Why a one-person business carries real data protection duties, and why clients now ask about them before they sign.

IN THIS CHAPTER

- Why the GDPR applies to freelancers, not only to big companies
- What counts as personal data in everyday freelance work
- Why clients ask security questions before they hire you
- The three habits that cover most of the risk

Priya is a freelance web developer. A bakery chain hires her to rebuild its online shop. In week one she receives an export of 14,000 customer accounts "to test the migration", a login to the payment dashboard and a shared folder of staff rotas. By week three the export sits in her downloads folder, a copy is on a USB stick she carries to a coworking space, and she has pasted a few rows into an AI chat window to debug an error.

Nothing malicious happened. Nobody was hurt. But if her laptop were stolen tomorrow, thousands of people's names, addresses and order histories would be in the hands of a stranger, and the bakery would have a very uncomfortable conversation to hold with its customers and its regulator.

Small does not mean exempt

A common myth is that data protection law is for corporations. It is not. The GDPR applies to anyone who processes personal data as part of a professional activity, and a freelancer is a business like any other. The rules that do not apply to you are mostly the ones triggered by size, such as appointing a data protection officer. The core duties, including keeping data secure, using it only as agreed and helping your client respond to breaches and requests, apply whether you have one client or one hundred.

> **GDPR IN PLAIN ENGLISH** **What counts as personal data**
>
> Personal data is **any information that relates to an identifiable person**, directly or indirectly: names, email addresses, phone numbers, postal addresses, IP addresses, customer IDs, photos, location data and online identifiers. A spreadsheet of "Customer 4471" with a purchase history is still personal data if someone can work out who that is. The definition is in Article 4(1) of the GDPR.

Where freelancers meet personal data



Figure 1 Four everyday ways client data lands on your desk

Even work that seems free of personal data often is not. A copywriter reviews customer testimonials. A designer receives photos of real employees. A bookkeeper handles payroll. A translator reads legal letters about named individuals. A consultant joins calls where staff problems are discussed. Assume personal data is present until you have checked.

Why clients now ask

More and more clients, particularly in Europe, send a short security questionnaire before they sign, or add a data processing agreement to the contract. They are not being difficult. Under the GDPR a business remains responsible for the personal data it shares with a supplier, and it must be able to show that it chose a supplier who offers sufficient guarantees (Article 28(1)). If you cannot answer simple questions about how you protect data, you are a risk they would rather not take.



The business case in four points

The flip side is an opportunity. A freelancer who can say "yes, I work under a DPA, I use encrypted storage, here is my deletion policy" stands out immediately. Data protection is increasingly a reason to hire you.

Three habits that cover most of the risk

KNOW WHAT YOU HOLD

Keep a simple list of which client data you have, where it lives and why you need it. You cannot protect what you cannot see.

SHARE ONLY WHAT IS NEEDED

Use the least data for the shortest time, send it by secure channels and agree the rules in writing before work starts.

DELETE ON TIME

When a project ends, return or delete client data, and be able to prove you did.

Figure 2 The core of this book

> FREELANCER TIP **Start small**
>
> Do not try to become compliant in a day. Pick one live client, apply the three habits to that project and use it as your template. By the third client the whole routine takes minutes.

BEFORE YOU MOVE ON

Which clients' data is on your laptop, phone or cloud storage right now?

Could you list every tool that stores or touches that data?

If your laptop disappeared tonight, whose information would be exposed?

PART I · KNOW WHAT YOU HOLD

CHAPTER

02

Mapping the Client Data You Hold

A one-page data map that shows what you have, where it lives, why you have it and when it goes.

IN THIS CHAPTER

- The kinds of client data freelancers typically handle
- Which data needs extra care (special categories and children)
- How to build a one-page data map in twenty minutes
- The "minimum needed" test for every file you accept

Before you can protect client data you have to know what you have. Most freelancers are surprised by the answer. Information drifts into downloads folders, email attachments, chat histories, cloud drives, backups and old laptops, and nobody ever decides to keep it there. A data map is simply a list that brings it into view.

The kinds of data you may meet

Common client data in freelance work

Type	Examples	Care level
Contact data	Names, emails, phone numbers, addresses, job titles	Standard
Account data	Customer or user accounts, usernames, order history	Standard to high
Financial data	Invoices, bank details, payment records, payroll	High
Employee data	CVs, contracts, performance notes, absence records	High
Special categories	Health, religion, trade-union membership, ethnicity, biometrics, sexual orientation, political views	Very high
Children's data	Pupils, young users, parents' details	Very high
Access data	Passwords, API keys, admin logins, tokens	Very high
Business confidential	Strategy, pricing, source code, unreleased products	High (not personal data, but covered by confidentiality)

WATCH OUT **Special categories need a stricter rule**

Article 9 of the GDPR prohibits processing health data, biometric data and other special categories unless a specific condition applies. If a client sends you medical records, a list of union members or similar, check that you really need them for the job. Often you can do the work with the data removed or replaced.

Build your data map

Open a spreadsheet and give it six columns. Fill in one row per client project. This is also the core of the records of processing that Article 30(2) can require from a processor, so the effort is never wasted.

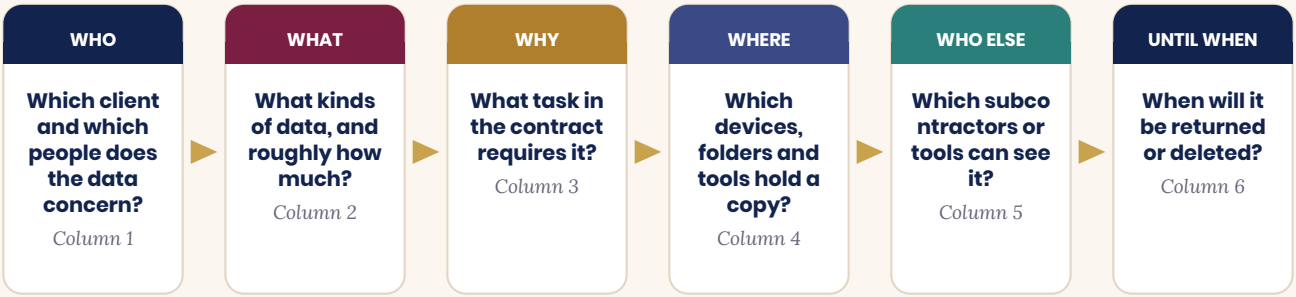


Figure 3 The data map in six questions

DO THIS NOW **Do this now**

Open your downloads folder, desktop and cloud drive and search for client names. Every spreadsheet, export and attachment you find is a row for your data map, or a file to delete.

Apply the minimum-needed test

Article 5(1)(c) calls it **data minimisation**: personal data must be adequate, relevant and limited to what is necessary. For a freelancer it is the most powerful habit of all, because data you never receive cannot be stolen from you. Before accepting any file, ask four questions.

CARELESS

- "Send me the whole customer database, I will filter it."
- Real production data used for testing.
- Full credit card or ID numbers in a spreadsheet.
- Admin logins shared with your own personal email.

CAREFUL

- "Please send only the fields and rows needed for this task."
- Anonymised or dummy data for testing wherever possible.
- Masked or partial values, such as the last four digits.
- Named, limited accounts for you, with multi-factor authentication.

Figure 4 Taking data: careless against careful

REAL-WORLD SCENARIO **the full export**

A freelance marketer is asked to segment a client's newsletter list. The client sends all 80,000 contacts with purchase totals, birthdays and support notes. The marketer needs only an email, a country and a last-order date. Because she asks for a reduced export, the client removes the sensitive columns, and when her email account is later phished there is far less to expose.

Pseudonymise and anonymise where you can

Pseudonymisation replaces direct identifiers with codes, so the data cannot be tied to a person without extra information kept separately. It reduces risk and is recognised in the GDPR as a safeguard (Article 4(5) and Article 32). **Anonymisation** goes further: the data can no longer identify anyone, and then it is no longer personal data at all. True anonymisation is harder than it looks, so do not assume that deleting names is enough when other details could still point to a person.

DATA MAP CHECKLIST

- [ ] I have searched my devices and cloud storage for client data.
- [ ] Each client project has one row in my data map.
- [ ] I know which special-category or children's data I hold, if any.
- [ ] I have asked clients to reduce exports to what the task needs.
- [ ] I use dummy or anonymised data for testing where possible.
- [ ] Every row has a planned deletion or return date.

PART II · YOUR LEGAL POSITION

CHAPTER

03

Your Role Under the GDPR

Controller or processor: the single question that decides what the law expects of you on each project.

IN THIS CHAPTER

- The difference between a controller and a processor
- Why you are usually a processor for client data and a controller for your own
- The duties each role carries
- What to do when the roles blur

The GDPR hands out roles. Who you are on a project decides which duties apply to you, which contract you need and who answers to the regulator when something goes wrong. Getting this right is half the battle.

Controller and processor in one minute

CONTROLLER

- Decides **why** and **how** personal data is processed.
- Usually the client, who owns the customer relationship.
- Chooses suppliers who give sufficient guarantees.
- Answers to individuals and the regulator first.

PROCESSOR

- Processes personal data **on behalf of** a controller and on its instructions.
- Usually you, when you build, manage or analyse the client's data.
- Must follow the written instructions and keep data secure.
- Can be fined and sued directly for its own breaches.

Figure 5 Two roles, two sets of responsibilities

The definitions are in Article 4(7) and 4(8). The test is not what the contract calls you. It is who decides the purposes and the essential means of the processing. If the client says "email these customers about the sale using this list", the client is the controller and you are carrying out their instructions.

You wear two hats

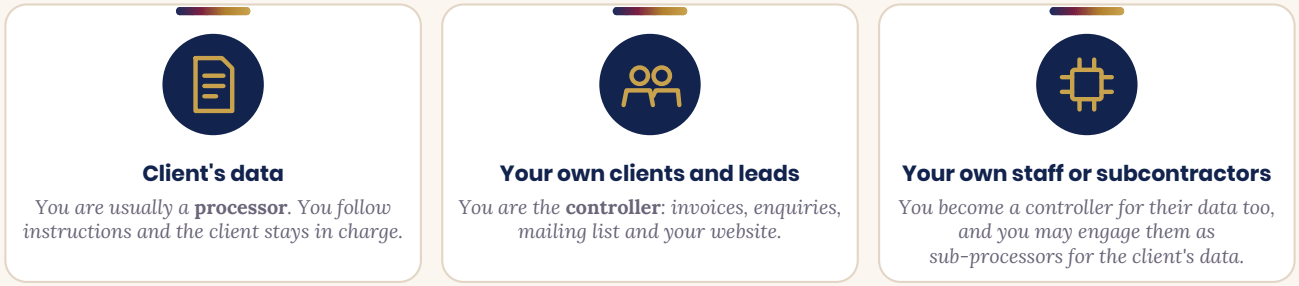


Figure 6 One freelancer, three kinds of data

GDPR IN PLAIN ENGLISH **Freelancers can be controllers for client data**

Sometimes you decide the purposes yourself. A market researcher who builds her own panel of survey respondents, a recruiter who keeps candidate profiles for future roles, or a coach who stores client notes in her own system is a controller for that data. When in doubt, ask who would have to explain to the individual why the data is held. That is the controller.

What each role has to do

Core duties at a glance

Duty	Controller	Processor (you, usually)
Lawful basis and transparency (Arts. 6, 13)	Yes	Not directly, but only act on instructions
Written contract (Art. 28)	Must have one	Must sign one and follow it
Security of processing (Art. 32)	Yes	Yes, in its own right
Sub-processors (Art. 28(2) and (4))	Must authorise	Need prior authorisation and a matching contract
Records of processing (Art. 30)	Records of activities	Records of processing for each controller
Breach notification (Arts. 33 and 34)	Notifies authority and people	Tells the controller without undue delay
Help with rights requests (Arts. 15 to 22)	Responds to individuals	Assists the controller
Deletion or return at the end (Art. 28(3)(g))	Decides which	Does it and confirms

What processors must not do

The most important restriction is easy to miss. A processor must only process personal data on the controller's documented instructions (Article 28(3)(a)). If you decide to use client data for your own purposes, such as training your own model, building your own mailing list or keeping a copy for your portfolio without permission, you step out of the processor role and into the controller role for that use. You then need your own lawful basis and may be breaching your contract and the law at the same time.

> WATCH OUT **Three things that quietly break the rule**
>
> **Reusing client data** for another client or a demo. **Keeping a copy** after the contract ends "just in case". **Giving it to a subcontractor** or tool the client has not approved. All three need the controller's permission first.

Do the small-business exemptions help?

Article 30(5) relaxes the duty to keep records of processing for organisations with fewer than 250 employees, but the relief does not apply if the processing is likely to result in a risk to people, is not occasional, or includes special categories of data. For most freelancers who work for clients regularly, the safest assumption is to keep a simple record anyway. The data map from Chapter 2 does the job. Likewise, you will rarely need a **data protection officer** (Arts. 37 to 39), which is required for specific situations such as large-scale monitoring or large-scale special-category processing.

If you are outside the EU

The GDPR can apply to you even if you live elsewhere. Article 3(2) covers a business outside the EU that offers goods or services to people in the EU or monitors their behaviour. If you process personal data on behalf of an EU client, the client's own obligations and the contract will pull you in regardless. In some cases a non-EU controller or processor must appoint an EU representative (Article 27). Treat it as part of the terms of working with European clients.

> DO THIS NOW **Label your projects**
>
> For each live project write one line in your data map: "Client X is controller, I am processor" or "I am controller". If you cannot decide, note why, and raise it with the client when you discuss the contract.

PART II · YOUR LEGAL POSITION

CHAPTER

04

Contracts, NDAs and Data Processing Agreements

The clauses that protect you and your clients, and how to ask for them without scaring anyone off.

IN THIS CHAPTER

- What Article 28 requires a processor contract to say
- How a DPA, an NDA and your main contract fit together
- Practical data protection clauses for freelance agreements
- What to do when a client's contract is one-sided

A contract is where good intentions become obligations. For a freelancer it does two jobs: it tells your client how you will treat their data, and it protects you by recording exactly what you were asked to do. Many freelance disputes begin with a missing clause, not a missing file.

Three documents, three jobs

How the paperwork fits together

Document	What it covers	Who usually supplies it
Services agreement or statement of work	Scope, fees, deadlines, ownership of work, liability	You or the client
Non-disclosure agreement (NDA)	Confidential business information and how long secrecy lasts	Usually the client
Data processing agreement (DPA)	How you handle personal data on the client's behalf (Article 28)	Usually the client, sometimes you

The NDA protects secrets. The DPA protects people. They overlap but are not the same. An NDA says nothing about security measures or sub-processors, and a DPA does not stop you describing the client's product strategy in public. For most client work you will want both, plus clear ownership and liability terms in the main agreement.

What Article 28 requires

Whenever a controller uses a processor, Article 28(3) requires a **binding contract** setting out the subject matter, duration, nature and purpose of the processing, the type of personal data and the categories of people. It must also contain a set of specific commitments from you.

WHAT YOUR DPA MUST INCLUDE (ART. 28(3))

- [ ] Process personal data only on the client's documented instructions.
- [ ] Make sure everyone with access is bound by confidentiality.
- [ ] Take appropriate security measures (Article 32).
- [ ] Use sub-processors only with the client's prior authorisation, under the same obligations.
- [ ] Help the client respond to requests from individuals about their rights.
- [ ] Help the client with security, breach notification and impact assessments.
- [ ] Delete or return all personal data at the end of the services, unless the law requires storage.
- [ ] Provide the information needed to show compliance and allow audits or inspections.

FREELANCER TIP **You do not have to write it from scratch**

Many clients already have a standard DPA. Many platforms publish theirs too. The EU Commission has also adopted standard contractual clauses for controller-processor contracts. Read what you are asked to sign instead of ticking "agree", and compare it with the list above.

Clauses worth adding to your own freelance agreement

If the client has no DPA, offer one. A short data protection schedule attached to your services agreement is usually enough. Below are the clauses that matter most, in plain language. Adapt them with a qualified adviser for your situation.

Practical data protection clauses

Clause	What it says in plain English
Roles	The client is the controller. The freelancer is the processor for personal data in the project.
Instructions	The freelancer will process personal data only as the contract and the client's written instructions require.
Security	The freelancer will use measures described in a schedule, such as encryption, multi-factor authentication and access control.
Sub-processors	The freelancer will use only the tools and helpers listed in an annex, and will tell the client before adding another.
Confidentiality	Everyone with access is bound by confidentiality, during and after the project.
Breach notice	The freelancer will tell the client without undue delay after becoming aware of a breach, with the facts they have.
Assistance	The freelancer will help the client answer rights requests and regulator questions within a reasonable time.
Return or deletion	Data is returned or deleted within an agreed number of days after the project, with written confirmation.
Liability	Liability for data protection breaches is capped in a way both sides accept, and insurance is noted if you have it.

WATCH OUT **Watch for unlimited liability**

Some client templates make the freelancer fully liable for every loss caused by a breach, with no cap. Under Article 82 a processor can be held liable for damage if it did not comply with its processor duties or acted outside the controller's instructions, and the contract can add more. Ask for a cap linked to your fees or insurance. A reasonable client expects the conversation.

Negotiating without friction

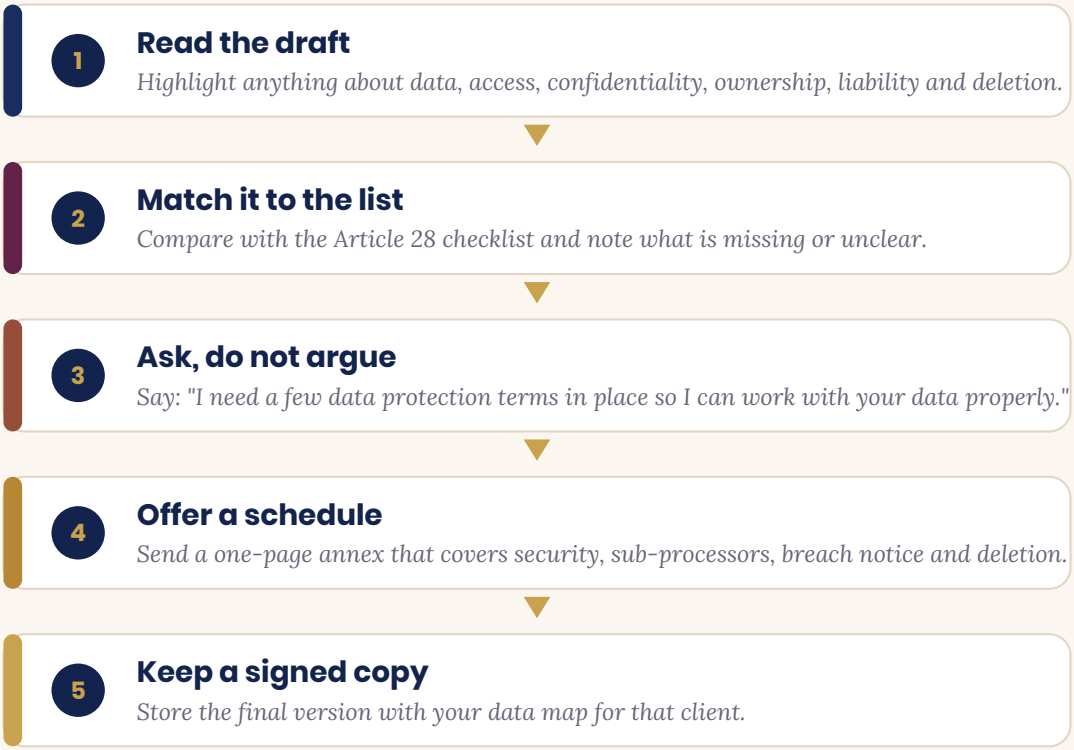


Figure 7 Asking for the right terms

REAL-WORLD SCENARIO **the missing clause**

A freelance analyst finishes a dashboard project. Six months later the client calls: a former employee's data appeared in a report shared with a partner, and the client wants to know where else the file was kept. The contract says nothing about copies. The analyst still holds the original export on an old laptop. Because nothing was agreed, neither side can say whether the copy should have been deleted. A single return-or-delete clause would have settled it on day one.

PART II · YOUR LEGAL POSITION

CHAPTER

05

Confidentiality in Everyday Freelance Life

Portfolios, case studies, screenshots, coworking spaces and video calls: where confidences leak without anyone meaning them to.

IN THIS CHAPTER

- What confidentiality means beyond the NDA
- How to show your work without exposing a client
- Safe habits for calls, cafes and coworking spaces
- Handling subcontractors and collaborators

Most leaks of client information are not hacks. They are conversations, screenshots, glances at a screen and helpful sharing. Confidentiality is mainly a habit of attention, and an NDA is only as strong as the daily behaviour behind it.

Confidential does not only mean personal

Personal data is protected by law. Business confidences are protected by contract, and sometimes by trade-secret law. They include unreleased products, prices, margins, customer lists, source code, strategy and internal disputes. A freelancer often sees all of it. Treat everything you learn through a client as confidential unless the client has said it is public.

> **GDPR IN PLAIN ENGLISH** **The duty continues after the project**
>
> Confidentiality clauses usually survive the end of the contract. Under Article 28(3)(b) of the GDPR, people authorised to process personal data on the client's behalf must be bound by confidentiality, and that commitment does not expire with the invoice. Check the length of your NDA and plan for it.

Showing your work without showing your clients

Your portfolio is your shop window, and it is also the place where freelancers most often overstep. Ask permission in writing before you name a client, show their screens or describe a project in detail. Do not assume that a result you built is yours to publish.



Figure 8 Four safe ways to build a portfolio

WATCH OUT **Screenshots carry more than you see**

A screenshot may include browser tabs, notifications, URLs with tokens, the sidebar of a chat and a sliver of someone's name. Crop tightly, check the edges and zoom to full size before posting. Files also carry metadata such as author names and previous revisions. Export a clean copy.

Calls, cafes and coworking

Everyday situations and safer habits

Situation	Risk	Safer habit
Working in a cafe	Shoulder-surfing, overheard calls, a stolen laptop	Use a privacy screen, headphones, keep the laptop in sight and lock it every time you stand up
Coworking space	Shared printers, unlocked screens, open Wi-Fi	Print nothing sensitive, use your own hotspot or a VPN you trust, lock the screen
Video calls	Background documents, recording by others, wrong attendees	Blur or use a plain background, check the participant list, close other windows before sharing a screen
Voice assistants and smart speakers	Devices listening in your workspace	Mute or unplug during confidential calls
Family or housemates	Others seeing your screen or using your laptop	Use a separate user account, lock when away, keep work files off shared devices
Travel	Border checks, theft, hotel Wi-Fi	Carry only the data you need, use full-disk encryption and sign out before travelling

Working with subcontractors and collaborators

The moment you hand client data to another freelancer, a translator, a designer or a virtual assistant, you have a sub-processor. Article 28(2) and (4) require the client's authorisation first, and your subcontractor must be bound by the same data protection obligations you accepted. In practice this means three things.

Before you share anything

1. Check your client contract and get written permission for the helper, general or specific.
2. Give them a short agreement with the same confidentiality, security and deletion terms.
3. Share the minimum, through your secure tool, and remove their access when the work ends.

FREELANCER TIP **You stay responsible**

If your subcontractor fails, the client will look to you, and under Article 28(4) you remain fully liable to the controller for your sub-processor's performance. Choose people you would trust with your own customers.

Using AI tools with client information

Pasting a paragraph into a chat assistant feels harmless, but it can be a disclosure to a third party. Whether that is allowed depends on the client contract, the tool's terms and settings, and the kind of data. Free consumer plans may use inputs differently from business plans, and some tools keep conversations for a time. Never put personal data, credentials, unpublished source code or confidential documents into a tool that your client has not approved. When you do use AI, use dummy data, strip identifiers, and write the rule into your contract. Chapter 8 covers this in detail.

CONFIDENTIALITY SELF-CHECK

Have I ever shown a client project publicly without permission?

Could someone nearby read my screen or hear my calls in the places I work?

Which of my helpers or tools has seen client information the contract does not mention?

PART III · PROTECT THE WORK

CHAPTER

06

Secure File Sharing

How to send, receive and store client files without leaving them in inboxes, public links and forgotten folders.

IN THIS CHAPTER

- Which channels are safe for which kinds of file
- How to set up links, permissions and expiry properly
- When to encrypt, and how to share passwords safely
- A simple rule set you can give every client

Sharing files is the moment of greatest exposure in freelance work. Data leaves one protected place and lands in another, often through an inbox, a chat window or a link that anyone can open. Good file sharing is not difficult. It is a handful of rules applied every time.

Why email attachments are the weak point

Email is convenient and nearly universal, but a normal email is closer to a postcard than a sealed envelope. Copies sit on several servers, in sent folders and on every device that syncs the mailbox, usually for years. A single wrong autocomplete sends a spreadsheet to the wrong person, which is one of the most common causes of a personal data breach. Use email for conversation and use a dedicated, access-controlled place for files.

REAL-WORLD SCENARIO **the wrong Alex**

A freelance HR consultant emails a spreadsheet of salary data to "Alex" at a client. The mail program completes the address with another Alex at a different company. She notices within minutes, but the message cannot be recalled. The client must now assess whether this is a breach that needs reporting. Had she shared the file through a restricted link, the wrong recipient would have been unable to open it.

Choose the channel by sensitivity

Which channel for which data

Sensitivity	Examples	Recommended channel
Public or low	Published copy, brand assets, public specs	Normal email, shared drive
Internal	Project plans, drafts, internal reports	Shared folder with named users
Personal data	Customer exports, contact lists, order data	Encrypted storage with named users, link expiry and logging
High risk or special category	Health data, IDs, payroll, credentials	Client's own secure platform, or end-to-end encrypted transfer plus a separate password
Credentials and secrets	Passwords, API keys, tokens	A password manager's sharing feature. Never email or chat them in plain text

The five rules of secure sharing

01
PREFER THE CLIENT'S SYSTEM

Whenever possible, work inside the client's own drive or platform so data does not move at all. You get access, they keep control.

02
NAMED PEOPLE, NOT PUBLIC LINKS

Share with specific accounts. "Anyone with the link" links are easy to forward, index or leak.

03
SET AN EXPIRY

Links and permissions should end on a date. Review access whenever a project phase ends.

04
ENCRYPT WHAT IS SENSITIVE

Use encrypted containers or end-to-end encrypted services for sensitive files, and send the password through a different channel.

05
KEEP A TRAIL

Use tools that log who opened what, and record in your data map where each file went.

Figure 9 Apply these every time

Encryption in plain English

Encryption scrambles a file so that only someone with the key can read it. It protects you in three places. **In transit**, when data moves across the internet, which reputable services do by default (look for "https"). **At rest**, when files sit on a drive or in the cloud, which full-disk encryption provides on a laptop. **End to end**, when only the sender and the recipient hold the keys, not even the service. The GDPR names encryption as an example of an appropriate security measure in Article 32(1)(a).

> **GDPR IN PLAIN ENGLISH** **Encryption can lower the stakes**
>
> If a laptop or USB stick is lost and the data was strongly encrypted with the key safe, the risk to the people concerned may be low enough that a breach does not need to be reported to individuals. It never removes your duty to record and assess the incident, but it can turn a disaster into an inconvenience.

Passwords for shared files

Sending a protected file

1. Compress the file into an encrypted archive or upload it to an encrypted share with a strong passphrase.
2. Send the link or file in one channel, such as email.
3. Send the passphrase in another channel, such as a messaging app or a phone call.
4. Set the link to expire and note the date in your data map.
5. After the client confirms receipt, delete your copies of the shared version.

Receiving files from clients

You can improve the situation from the other side too. Tell clients how you would like to receive data and what you would like to receive. A short "how we share files" note at project kickoff prevents most problems.

GROUND RULES TO SEND EVERY NEW CLIENT

- [ ] Share files through [agreed platform], not by email attachment.
- [ ] Send only the fields and rows needed for the task.
- [ ] Never send passwords by email or chat. Use the password manager's sharing feature.
- [ ] Tell me when the data contains health, financial or children's information.
- [ ] Confirm who may access the files and who must be removed at the end.
- [ ] Tell me within one working day if you think a file went to the wrong person.

FREELANCER TIP **USB sticks are for storage, not delivery**

A USB stick is easy to lose and hard to track. If you must use one, encrypt it, label it with the project code only and wipe it after use. Do not treat it as a backup.

PART III · PROTECT THE WORK

CHAPTER

07

Locking Down Your Devices and Accounts

The home-office security basics that stop most attacks, in an order that fits a one-person business.



IN THIS CHAPTER

- The security measures Article 32 expects of a small business
- A priority order for passwords, MFA, updates, encryption and backups
- How to secure your home office and your network
- Safe separation of personal and client data

You do not need a security team to be a hard target. Most attacks on small businesses use the same few doors: stolen passwords, phishing emails, unpatched software and lost devices. Closing those doors covers most of the risk, and it takes less time than writing a proposal.

What the law actually asks for

Article 32 requires both controllers and processors to implement **appropriate technical and organisational measures** to ensure a level of security suited to the risk, taking into account the state of the art, the costs and the nature of the data. It gives examples such as pseudonymisation and encryption, the ability to keep systems confidential and recoverable, and regular testing. For a freelancer, "appropriate" means sensible and proportionate: more care for health or payroll data than for a public brochure, and no excuses for skipping the basics.

The security basics, in priority order

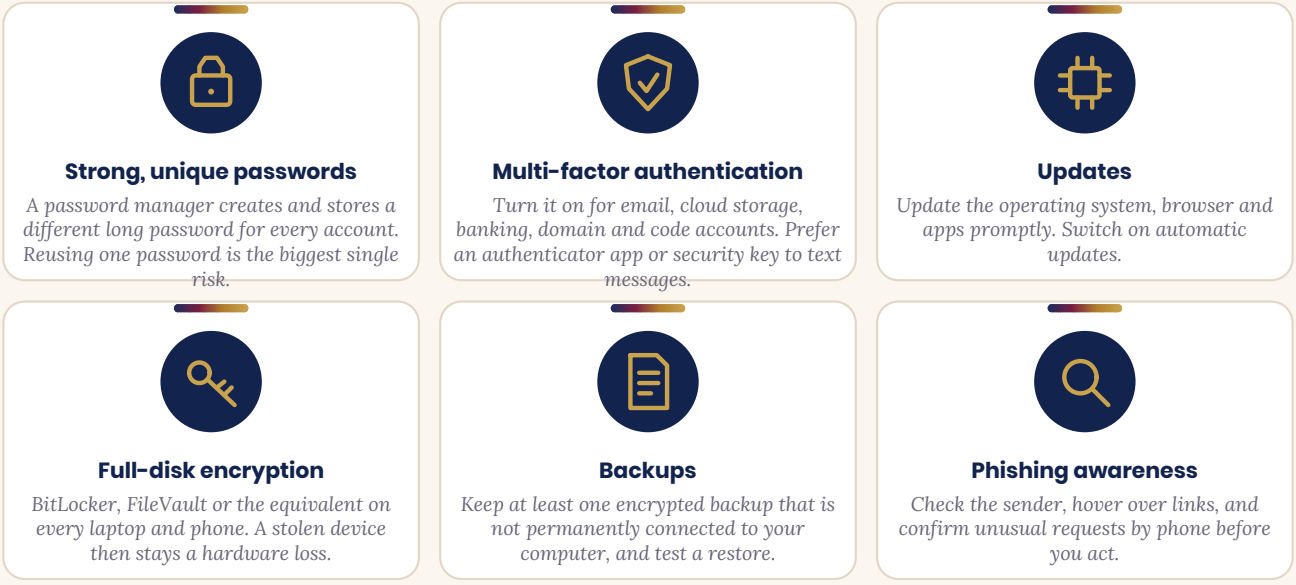


Figure 10 Six measures that matter most

> **WATCH OUT** **Your email is the master key**
>
> If an attacker controls your email, they can reset almost every other password you have. Give it the strongest password you own, enable multi-factor authentication and review forwarding rules and connected apps now and then.

Make a separate workspace

ONE MIXED SETUP

- Family and work share one login on one laptop.
- Client files live in the downloads folder.
- Browser holds personal and client accounts together.
- Everything syncs to every device by default.

CLEAN WORK SETUP

- A separate user account or device for client work.
- One organised folder per client, encrypted and backed up.
- A separate browser profile for client accounts.
- Sync limited to the devices you control.

Figure 11 Mixed everyday use against a clean work setup

Home office and network

Your home network is your office network. A few small changes make it much safer.

HOME-OFFICE SECURITY CHECKLIST

- [ ] Router password changed from the default and the router firmware is up to date.
- [ ] Wi-Fi uses WPA2 or WPA3 with a long passphrase, and a guest network exists for visitors and smart devices.
- [ ] Smart speakers, TVs and cameras are on the guest network, not the work network.
- [ ] Screen lock set to one or two minutes with a password, biometric or PIN.
- [ ] A trusted VPN or personal hotspot is used on public Wi-Fi.
- [ ] Printers are used for client documents only when necessary, and papers are shredded.
- [ ] Antivirus or built-in protection is switched on.

Devices that go missing

Loss and theft is a leading cause of reported breaches, and it is wholly preventable. Turn on the device-finding and remote-wipe features on laptops and phones. Note the serial numbers. Use a screen lock and encryption so that a lost device is an inconvenience. If a device that held client data goes missing, you will need to tell your client quickly (Chapter 10).

FREELANCER TIP **Do not use personal accounts for client work**

A personal webmail address, a personal cloud account or a messaging app set to auto-save images does not belong in client projects. Use business accounts under your own control, with MFA, so you can shut them cleanly when work ends.

Accounts and access for clients' systems

When a client gives you access

1. Ask for a named account for you, not a shared login, with the lowest permissions needed.
2. Turn on multi-factor authentication for that account straight away.
3. Store the credentials in your password manager, never in notes or email.
4. Do not give access to anyone else, including subcontractors, without written permission.
5. Ask the client to disable your account on the last day of the contract, and confirm in writing.



Figure 12 A realistic security routine for a freelancer

PART III · PROTECT THE WORK

CHAPTER

08

Tools, Sub-Processors, AI and International Transfers

How to choose the apps you use with client data, and keep the list your clients are entitled to see.

IN THIS CHAPTER

- Why every tool that touches client data is a sub-processor question
- A due-diligence checklist for cloud tools
- How to use AI assistants without leaking client information
- What international transfers mean for a freelancer

Your toolkit is also your risk list. Cloud storage, project boards, invoicing, time-tracking, email, video calls, design platforms and AI assistants each hold a piece of client information, and each is run by a company you do not control. The GDPR expects you to know which ones those are and to choose them with care.

Every tool is a decision

If a service stores or processes personal data on your client's behalf, it acts as a sub-processor under Article 28(2) and (4). That means the client's contract may require approval, the provider must be bound by similar obligations, and you stay responsible for their performance towards the client. For freelancers this sounds heavy, but most reputable providers publish a standard DPA, a list of their own sub-processors and a security page. Your job is to read them and choose well.

Due diligence in ten minutes

BEFORE YOU PUT CLIENT DATA IN A NEW TOOL

- [ ] The provider offers a data processing agreement I can accept.
- [ ] It publishes where data is stored and who its sub-processors are.
- [ ] Encryption, multi-factor authentication and access controls are available.
- [ ] Data can be exported and deleted on request.
- [ ] It does not use customer content to train its own models, unless I can opt out in the plan I use.
- [ ] Its security documentation or certifications are public and recent.
- [ ] The client has approved it, or my contract allows general use of tools like it.
- [ ] I have recorded the tool in my data map.

FREELANCER TIP **Keep a one-page tool register**

List each tool, what it holds, where its data is stored, the date you accepted its DPA and which clients it touches. When a client asks "who else sees our data?", you can answer in a minute.

AI assistants and client data

AI tools are the newest and fastest-growing source of accidental disclosure. The risks depend on the tool, the plan and the settings: whether inputs are stored, who can review them, whether they are used for training and where they are processed. Consumer and business plans of the same product often treat data differently, so read the terms of the exact plan you use.

Using AI safely with client work

Do	Do not
Use dummy or anonymised data to test prompts and workflows	Paste customer lists, contracts, health or payroll data into a general chat tool
Choose a business plan with a DPA and no training on your inputs	Use a free personal account for client material
Ask the client for permission, in writing, before using AI on their files	Assume "it is only a draft" makes it safe
Check AI output for invented facts, copied text and leaked names	Submit AI-generated work as verified without review
Delete chat histories and shared links when the project ends	Leave conversations containing client data in your account

GDPR IN PLAIN ENGLISH **AI does not change who is responsible**

If you use an AI service to process personal data for a client, the service is a sub-processor, and the usual rules apply: client authorisation, a contract, security and a lawful route for data leaving the EU. Some clients now include an AI clause in their agreements. Read it and follow it.

International transfers

The GDPR restricts transfers of personal data outside the European Economic Area unless an adequate level of protection is ensured (Chapter V, Articles 44 to 49). The common routes are an adequacy decision by the European Commission, appropriate safeguards such as the standard contractual clauses, or, in narrow cases, an exception listed in Article 49. A transfer happens when data is sent to, or can be accessed from, a country outside the EEA, including through a cloud provider's servers or support staff.

WATCH OUT **The rules in this area change**

Adequacy decisions, including the EU-US Data Privacy Framework, are reviewed and challenged from time to time. Do not rely on memory. Check the European Commission's current list and your provider's transfer documentation, and follow what your client's contract says about where data may be stored.

You travel, the data stays put

Freelancers who work from several countries have an extra question: is the data crossing a border because you do? Opening a client's cloud folder from a laptop in a non-EEA country can count as a transfer or remote access. Check the contract and the client's policy before you travel, and prefer working inside the client's own environment so that the data itself does not move. Border searches and local laws can also affect devices, so carry only what the trip requires.

Art. 28
The article governing processors and sub-processors

Chap. V
The chapter on transfers to countries outside the EEA

1 list
A single tool register answers most client questions

0
Reasons to use a client's data in a tool the contract does not allow

Tools and transfers at a glance

PART IV · KEEP IT SAFE OVER TIME

CHAPTER

09

Retention, Deletion and Closing a Project

Keeping client data only as long as you need it, and finishing every project with a clean exit.

IN THIS CHAPTER

- Why old data is a liability and what the GDPR says about storage
- The difference between returning, deleting and archiving
- How to close a project step by step
- How to respond when someone asks about their data

Most freelancers are good at starting projects and poor at ending them. Files stay in folders, accounts stay open and backups quietly hold a copy of everything. Years later a laptop is stolen or an old cloud account is breached, and a client whose project ended long ago is back in the news.

The principle: storage limitation

Article 5(1)(e) says personal data must be kept in a form that identifies people **for no longer than necessary** for the purposes for which it is processed. As a processor you do not decide the retention period. The client does, and it should be written into the contract. When the services end, Article 28(3)(g) says you must, at the client's choice, delete or return all the personal data and delete existing copies unless the law requires storage.

> WATCH OUT **"Just in case" is not a reason**
>
> Keeping a copy in case the client asks again, or in case you need to prove what you did, feels sensible but usually breaks the contract and the law. If you need records for your own protection, keep your own business records, such as invoices, emails and the final deliverables, not the underlying personal data.

What you may need to keep

Typical retention in freelance work

What	Usually kept	Notes
Client's personal data (exports, test data, access)	Until the end of the project, then returned or deleted	Agree the date in the contract
Your invoices and accounting records	Per national tax and accounting law, often several years	Keep only what the law requires
Signed contracts	For the period you may need to defend a claim	Check limitation periods in your country
Final deliverables	As agreed in the contract	Remove embedded personal data first
Backups	Until they cycle out	Document how long and whether you can delete from them

GDPR IN PLAIN ENGLISH **Legal retention periods vary**

Tax, accounting and limitation periods differ between countries and professions. Check the rules in your own country, or ask an accountant, before you decide how long records stay. Do not copy a number from a blog.

The closing routine

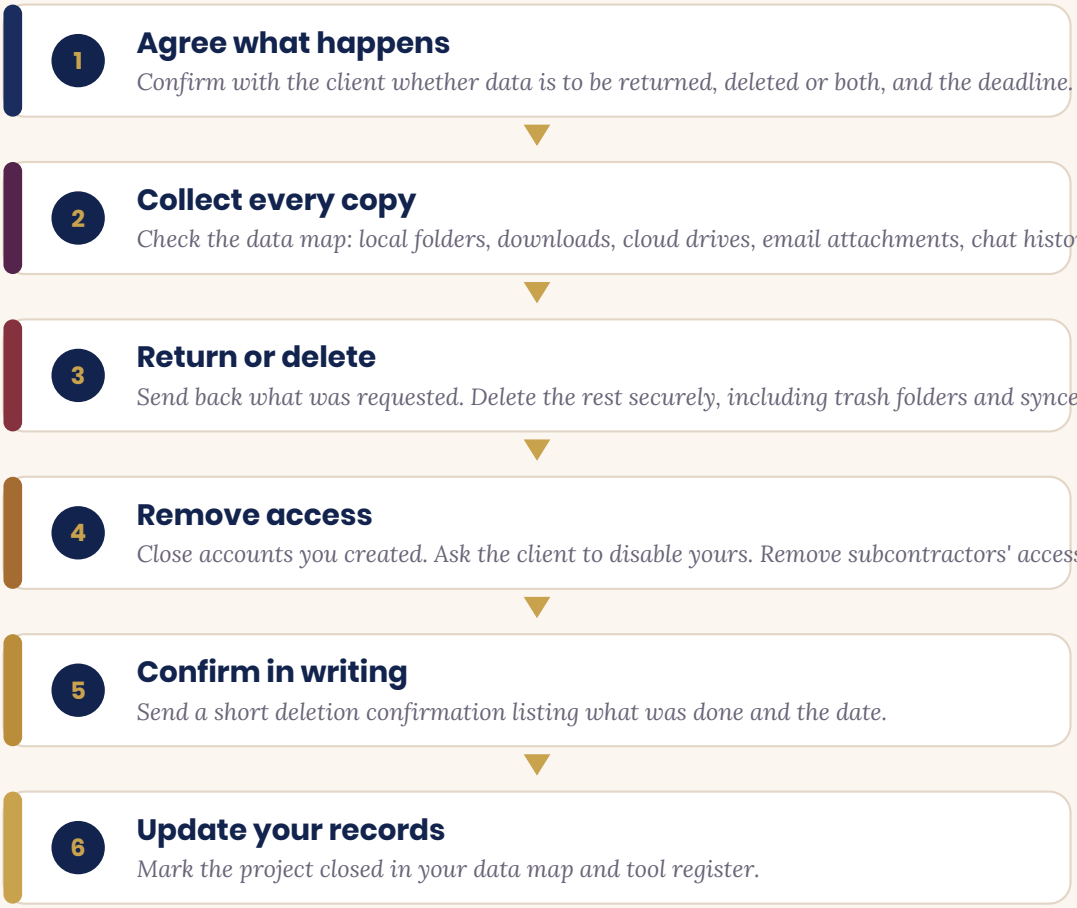


Figure 13 How to close a project cleanly

Deleting properly

Pressing delete moves a file to the trash. Emptying it removes the pointer, not always the data. On a modern encrypted laptop, normal deletion plus an emptied trash is usually enough, because the data is unreadable without the key. For old drives, USB sticks or anything unencrypted, use a secure wipe tool or physically destroy the device. Remember cloud storage versions, shared links, email attachments and chat uploads, which are easy to forget.

DELETION SWEEP

- [ ] Project folder deleted and trash emptied.
- [ ] Downloads folder and desktop checked for exports and attachments.
- [ ] Email searched for attachments and exports from this client.
- [ ] Cloud drive, shared links and versions removed.
- [ ] Messaging and project tools cleared of uploaded files.
- [ ] Backups noted in the register with their expiry date.
- [ ] USB sticks and old devices wiped or destroyed.
- [ ] Subcontractors confirmed deletion in writing.

When individuals come knocking

People have rights over their data, including access, correction and deletion (Articles 15 to 22). They exercise them against the **controller**, which is your client. If someone contacts you directly about client data, do not answer on your own. Pass the request to the client promptly, as your contract should require, and help them respond within the one-month deadline the GDPR sets (Article 12(3)).

FREELANCER TIP **A one-line rule**

If anyone asks you about their personal data in a client's project, reply politely that you work on behalf of the client, forward the request the same day and do not delete or change anything unless the client instructs you to.

REAL-WORLD SCENARIO **the archive that never ended**

A freelance developer keeps a complete database dump from a former client "for reference". Two years later his cloud account is compromised through a reused password. The dump contained 22,000 customer records. The former client must notify its regulator, explain why a supplier still held the data and decide whether to inform customers. A deletion email in week one of the project's end would have prevented it all.

PART IV · KEEP IT SAFE OVER TIME

CHAPTER

10

When Something Goes Wrong

Lost laptops, wrong recipients and hacked accounts: what a freelancer must do, and how fast.

IN THIS CHAPTER

- What counts as a personal data breach in freelance work
- What Article 33(2) requires of a processor
- A first-hour plan for the most common freelance incidents
- How to tell your client, and what to record

Mistakes happen to everyone. A file goes to the wrong person, a laptop is left on a train, a password turns up in a leak. What separates a manageable incident from a serious one is mostly speed and honesty in the first hours.

What is a personal data breach?

Article 4(12) defines it as a breach of security leading to the **accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to** personal data. It is wider than hacking. Sending an email to the wrong person, losing a device, deleting files by mistake or letting a subcontractor see data they should not all count.

CONFIDENTIALITY
Someone who should not see the data does. A misdirected email, a public link, a stolen laptop, a hacked mailbox.

INTEGRITY
Data is changed without permission. A corrupted file, an altered spreadsheet, tampered records.

AVAILABILITY
Data is lost or unusable. Ransomware, accidental deletion, a dead drive with no backup.

Figure 14 Three kinds of breach

The processor's duty: tell the controller

> **WHAT GDPR REQUIRES** **Article 33(2)**
>
> A processor **shall notify the controller without undue delay after becoming aware of a personal data breach.** The 72-hour deadline to notify the supervisory authority belongs to the controller and starts when the controller becomes aware, so every hour you hold back is an hour your client loses. Many contracts set a shorter deadline for you, often 24 or 48 hours, so check yours.

You do not decide whether the breach must be reported to the regulator or to the people affected. The client does, based on the risk to those people (Articles 33 and 34). Your job is to report quickly, give the client what you know, and help them assess it. If the incident also involves your own data, such as your mailing list or invoices, you are the controller for that part and the 72-hour clock is yours.

Your first hour

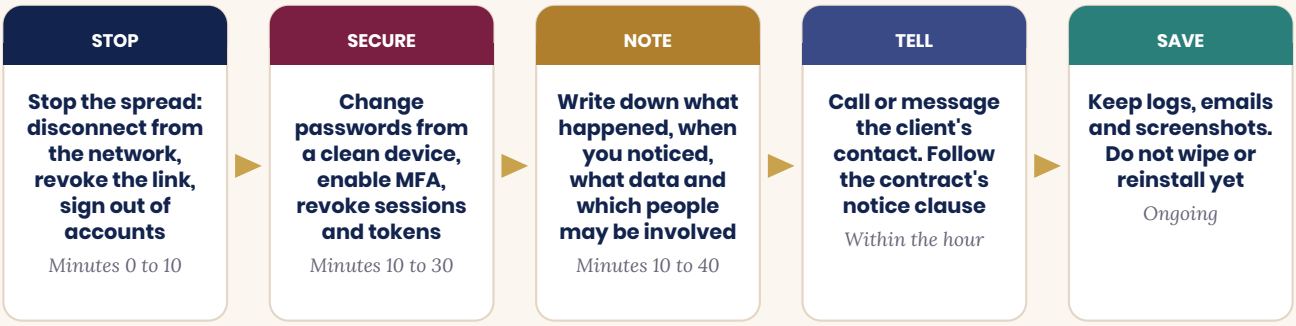


Figure 15 First hour of a freelance incident

WATCH OUT **Do not hide it**

It is tempting to fix a small mistake quietly. Do not. A breach that comes to light later, with a delay and a cover-up, is much worse for your client and for your reputation. Clients usually forgive an honest early message and rarely forgive a discovered silence.

Four common incidents

Playbooks for typical freelance incidents

Incident	Do this first	Tell the client
Email sent to the wrong person	Ask the recipient to delete it and confirm in writing. Check what the file contained	Yes, with the file, recipient and your recovery steps
Lost or stolen laptop or phone	Remote lock and wipe. Revoke sessions and passwords. Note whether it was encrypted	Yes, say what client data it could reach
Hacked email or cloud account	Reset password, MFA, review forwarding rules and connected apps	Yes, with a list of affected mailboxes and shared files
Subcontractor or tool breach	Ask the provider for facts in writing. Stop sharing new data	Yes, once you are aware, even if details are incomplete

What to tell your client

Breach notice to a client (draft)

```
Subject: Urgent: possible personal data incident on [project]

Hello [name],
I need to tell you about an incident that may affect personal data
from [project].

What happened: [short description]
When I noticed: [date, time]
What data may be involved: [types of data, roughly how many people]
What I have done so far: [containment steps]
What I am doing next: [next steps, timing]
What I need from you: [decision, contact, access]

I will update you by [time]. My contact for this incident is [phone].
```

FREELANCER TIP **Facts, not guesses**

Give the client what you know and say what you do not know yet. You may send updates in phases. The EDPB guidelines on breach notification accept that information can follow in stages when it is not all available at once.

Keep a record of every incident

Article 33(5) requires controllers to document every breach, including the facts, effects and actions taken, whether or not it is reported. As a processor you should keep a similar note of every incident you have, large or small, so you can help your client and show regulators that you take it seriously. The breach log in the Bonus toolkit is built for this.

REAL-WORLD SCENARIO **the train seat**

A freelance translator leaves her laptop on a train. It holds contracts, scanned IDs of a client's employees and a folder of drafts. Her disk is encrypted, the device finds itself offline and she remotely locks it within the hour. She calls the client's contact straight away and sends the draft notice with the facts. Because of the encryption and the speed, the client records the incident, decides the risk is low and thanks her for the honesty. The same loss with no encryption and a day's silence would have been a very different conversation.

PART IV · KEEP IT SAFE OVER TIME

CHAPTER

11

Your 30-Day Freelancer Protection Plan

A realistic month-long routine that takes you from where you are to a business clients trust with their data.

IN THIS CHAPTER

- A week-by-week plan that fits around client work
- A short list of questions to answer when a client asks about security
- How to describe your data protection as a selling point
- An annual review that keeps everything current

You have the knowledge. The remaining task is turning it into a routine. This plan breaks the work into four weeks of small tasks, none longer than an hour. Do them in order, tick them off and keep the results in one folder named "Data protection".

The 30-day plan

Week 1

Know what you hold

Search devices and cloud storage for client data, build your data map, delete what you no longer need and label each project controller or processor.

Week 2

Secure the basics

Install a password manager, switch on MFA everywhere, turn on full-disk encryption, update devices and set up a tested backup.

Week 3

Fix the paperwork

Prepare a short data protection schedule for your contracts, a tool register, a client onboarding note and a deletion confirmation template.

Week 4

Practise and prepare

Write your incident card, run a ten-minute mock incident, review access for every live client and book your first annual review.

Figure 16 Four weeks to a protected freelance business

30-DAY CHECKLIST

- [ ] Data map complete for every live client.
- [ ] Old client files returned or deleted, with confirmation sent.
- [ ] Password manager in use and email secured with MFA.
- [ ] Laptop and phone encrypted, locked and finding-enabled.
- [ ] At least one tested, encrypted backup.
- [ ] Data protection schedule ready to attach to contracts.
- [ ] Tool register lists every service touching client data.
- [ ] "How we share files" note ready for new clients.
- [ ] Incident card printed and kept offline.
- [ ] Client access list reviewed and unused access removed.

Answering a client's security questionnaire

Some clients will send a form. Do not be intimidated. The questions are nearly always variations on the same theme, and the work in this book gives you the answers.

Questions clients ask and where to find your answer

Typical question	Your answer comes from
Do you have a data processing agreement in place with your clients?	Chapter 4 and your DPA schedule
Where is our data stored, and by which providers?	Tool register, Chapter 8
How do you share and protect files?	Chapter 6 rules and encryption practice
Are devices encrypted and protected with MFA?	Chapter 7 checklist
Do you use subcontractors or AI tools?	Chapters 5 and 8
What happens if there is a breach?	Chapter 10 playbooks and breach notice
How and when is our data deleted?	Chapter 9 closing routine

FREELANCER TIP **Turn it into a selling point**

A short "How I protect your data" page on your website, or a one-page PDF you send with proposals, shows professionalism. You do not need to publish technical details. Four or five plain sentences covering contracts, encryption, access control, subcontractors and deletion are enough to reassure most clients.

Your annual review

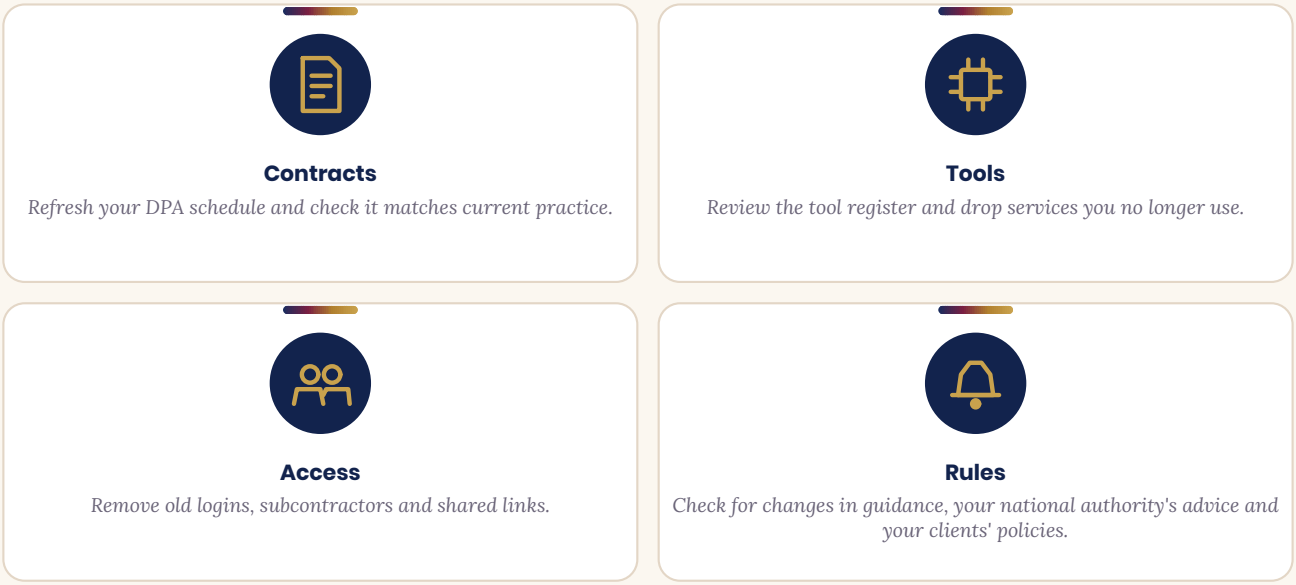


Figure 17 Once a year, spend an hour on these

GOOD TO KNOW **Keep an eye on the rules**

The European Commission's Digital Omnibus proposals, published in late 2025, suggest changes to parts of EU data and AI law. At the time of writing they were proposals that had not been finalised, so check EUR-Lex and your supervisory authority's website for what applies when you read this.

A closing word

Protecting client data is part of being a professional. It is invisible when it works and costly when it does not. A freelancer who knows what they hold, shares it carefully, keeps contracts tidy and deletes on time is easy to hire and easy to recommend. Start with one project this week, build the habit and let it grow.

GOOD PRACTICE **Your three promises**

I will know what I hold. I will share only what is needed, through safe channels. I will delete it when the work is done.

BONUS

Freelancer Data Protection Toolkit

Data map, client data sheet, tool register, DPA checklist, closing record and incident card. Fill them in on screen or print them.

IN THIS CHAPTER

- A data map and a tool register
- A client data sheet for every new project
- A closing record to prove deletion
- An incident card and a draft client notice

WATCH OUT **How to use the toolkit**

The tables have fillable fields in the PDF and ruled boxes in print. Complete them while the project is fresh, and keep the finished sheets in one folder per client. These are educational templates, not legal advice: adapt them to your business and check requirements in your country.

DATA MAP (ONE ROW PER CLIENT PROJECT)

Client	Role (controller or processor)	Data types and people	Purpose	Where stored	Who else has access	Delete or return by
e.g. Bakery Ltd	*Processor*	*Customer emails, order history, about 14,000 people*	*Shop migration*	*Encrypted laptop folder, client drive*	*None*	*30 days after launch*

TOOL AND SUB-PROCESSOR REGISTER

Tool	What it holds	Data location	DPA accepted on	Client approval	Clients affected	Review date
e.g. Cloud storage	*Project files*	*EU region*	*12 Jan 2026*	*In contract annex 2*	*Bakery Ltd*	*12 Jan 2027*

WORKSHEET

Client data sheet

Fill in at kickoff and store with the signed contract.

Client and contact person

Project and expected end date

Controller or processor, and why

Types of personal data involved

Special-category or children's data?

How data will be shared (channel, expiry)

Subcontractors or tools approved

Where the data will be stored

Deadline to return or delete

Breach notice deadline and contact

Signed DPA or contract clause location

Checklist: reviewing a client's DPA

CHECK THE DRAFT AGAINST ARTICLE 28(3)

- [ ] Subject matter, duration, nature and purpose are clear.
- [ ] Types of data and categories of people are listed.
- [ ] I only act on documented instructions.
- [ ] Confidentiality duties are described and acceptable.
- [ ] Security measures are realistic for a one-person business.
- [ ] Sub-processor approval route is workable.
- [ ] Assistance with rights requests and breaches has a sensible deadline.
- [ ] Return or deletion is defined, with timing.
- [ ] Audit rights are reasonable and not disruptive.
- [ ] Liability is capped or insured.

PROJECT CLOSING RECORD

Client and project	Data returned (what, when)	Data deleted (what, when)	Access removed	Subcontractors confirmed	Backups expire on	Client confirmation sent
e.g. Bakery Ltd shop	*Export returned 3 Mar*	*Local folder, email attachments 3 Mar*	*Admin account, links*	*Designer 3 Mar*	*3 Apr*	*4 Mar*

INCIDENT LOG

Date and time	What happened	Data and people involved	Client told (when, how)	Actions taken	Outcome
e.g. 12 Nov 10:15	*Email sent to wrong Alex*	*Salary file, 14 people*	*Called 10:40, email 10:50*	*Recipient deleted file*	*Client recorded, low risk*

Incident card

Freelancer incident card (keep a printed copy)

```
1. STOP    Disconnect, revoke link, sign out, lock the device.
2. SECURE  New passwords from a clean device. MFA on. Revoke sessions.
3. NOTE    What, when, which client data, how many people.
4. TELL    Call the client first, then email. Use the contract's notice clause.
5. SAVE    Keep logs, emails, screenshots. Do not wipe yet.
6. LOG     Add to the incident log. Review what to change.

Client contact (name, mobile, email): [ ]
Backup contact at client: [ ]
My insurer and hotline (if any): [ ]
Local data protection authority breach form: [ ]
```

Draft: data protection schedule for your contract

Data protection schedule (draft, adapt before use)

```
1. Roles. The Client is the controller. The Freelancer is the processor
   for personal data processed under this agreement.
2. Instructions. The Freelancer processes personal data only on the
   Client's documented instructions, including this agreement.
3. Confidentiality. Everyone with access is bound by confidentiality.
4. Security. The Freelancer applies the measures in Annex 1, including
   encryption, multi-factor authentication and access control.
5. Sub-processors. Only those in Annex 2, with prior written notice
   of any change.
6. Assistance. The Freelancer helps the Client with rights requests,
   security, breach notification and impact assessments.
7. Breach notice. The Freelancer informs the Client without undue
   delay, and within [48] hours, after becoming aware of a breach.
8. Return or deletion. At the end of the services, within [30] days,
   the Freelancer returns or deletes all personal data as instructed
   and confirms in writing, unless the law requires storage.
9. Audit. The Freelancer provides information reasonably needed to
   show compliance.
```

Draft: deletion confirmation

Deletion confirmation (draft)

```
Subject: Confirmation of data return and deletion: [project]

Hello [name],
As agreed, I confirm that on [date] I:
- returned [files, systems] to you through [channel];
- permanently deleted all other personal data from [project],
  including local folders, email attachments, cloud storage and
  messaging tools;
- removed my access to [systems] and asked [subcontractors] to do the same.
Backups containing the data will be overwritten by [date].
Please tell me if you need any further confirmation.
```



Figure 18 Quick severity guide for freelancers

Plain-English Glossary

The terms you will meet on the way, in alphabetical order.

Anonymisation	Changing data so that no person can be identified from it, by anyone, by any reasonable means. Anonymous data is outside the GDPR.
Controller	The organisation or person that decides why and how personal data is processed (Art. 4(7)). Usually your client.
Data minimisation	Collecting and keeping only the personal data needed for the purpose (Art. 5(1)(c)).
Data processing agreement (DPA)	The contract between a controller and a processor required by Art. 28(3).
Data subject	The person the personal data is about.

DPO	Data Protection Officer: an independent adviser required in some organisations (Arts. 37 to 39).
Encryption	Scrambling data so only someone with the key can read it.
End-to-end encryption	Encryption where only the sender and recipient hold the keys.
International transfer	Sending personal data, or making it accessible, to a country outside the EEA (Chapter V).
Multi-factor authentication (MFA)	Logging in with two or more proofs of identity, such as a password and an authenticator code.
NDA	A non-disclosure agreement that protects confidential business information.
Personal data	Any information relating to an identified or identifiable person (Art. 4(1)).
Personal data breach	A security breach leading to accidental or unlawful loss, alteration, disclosure of or access to personal data (Art. 4(12)).
Processor	A person or organisation that processes personal data on behalf of a controller (Art. 4(8)). Usually you.
Pseudonymisation	Replacing direct identifiers with codes so data cannot be linked to a person without separate extra information.
Special-category data	Data revealing health, ethnicity, religion, politics, union membership, sexual orientation, genetics or biometrics (Art. 9).
Storage limitation	The principle that data is kept no longer than necessary (Art. 5(1)(e)).
Sub-processor	A processor engaged by another processor, such as a tool or helper you use for client data (Art. 28(2) and (4)).
Supervisory authority	The national body that enforces the GDPR, also called the data protection authority.

Official Sources & Further Reading

Where the legal claims in this book come from, and where to check what applies today.

Always prefer the primary sources below to summaries, including this one. Web addresses change: if a link has moved, search the official site for the title shown. Guidance is updated regularly, so check for the latest version before relying on it.

Primary EU law (EUR-Lex)

- **General Data Protection Regulation (GDPR)**, Regulation (EU) 2016/679. Notably Art. 3 (territorial scope), Art. 4 (definitions), Art. 5 (principles), Art. 9 (special categories), Art. 12 and Arts. 15 to 22 (rights), Art. 24 to 28 (controller and processor duties), Art. 30 (records), Art. 32 (security), Arts. 33 and 34 (breaches), Arts. 44 to 49 (transfers) and Arts. 82 and 83 (liability and fines). eur-lex.europa.eu/eli/reg/2016/679/oj
- **Commission Implementing Decision (EU) 2021/915** on standard contractual clauses between controllers and processors under Art. 28.
- **Commission Implementing Decision (EU) 2021/914** on standard contractual clauses for transfers to third countries.

Regulators and guidance

- **European Data Protection Board (EDPB)**: Guidelines 07/2020 on the concepts of controller and processor under the GDPR, Guidelines 9/2022 on personal data breach notification and guidance on international transfers: edpb.europa.eu
- **Your national data protection authority**: most publish guidance for small businesses, breach-reporting forms and processor guidance. Find yours on the EDPB website.
- **European Commission**: list of adequacy decisions and information on standard contractual clauses: commission.europa.eu

WATCH OUT **What this book could not verify for you**

Retention periods, contract-law limits on liability and NIS2 duties differ by country and sector. The EU-US Data Privacy Framework, the Digital Omnibus proposals and other developments may have changed since this book was written. The scenarios are fictional. Check each point against the primary source and take advice from a qualified professional before relying on it.

About the Author

Zirlandia Milkovic

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that freelancers and founders should not need a legal degree to understand the rules that apply to them.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy freelancers and founders can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Stay in touch

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other freelancers and small businesses find it.

> GOOD TO KNOW **Note to the reader**
>
> This book is educational and not legal advice. Laws and guidance change, so check the sources in the previous section and consult a qualified professional about your own circumstances.



Know what you hold.
Share it safely.
Delete it on time.

ZIRLANDIA MILKOVIC